Secure Coding, Threat Modelling, and Testing

1. What are secure coding practices, and why are they important in software development?
2. What is threat modelling, and which framework (e.g., STRIDE) is commonly used?
3. Explain the difference between SAST and DAST in security testing.
4. What are the benefits of performing code reviews from a security perspective?
5. Define the principle of least privilege and give an example in application development.

Input Validation, Sanitization & Queries

6. What is input validation, and how does it prevent security vulnerabilities?
7. Compare whitelist and blacklist approaches in input validation.
8. What is pattern matching, and how is it used in validating user input?
9. Why is canonicalization important in preventing path traversal attacks?
10. What are parameterized queries, and how do they prevent SQL injection?

Android Architecture & Mobile Security

11. Describe the key layers of Android architecture.
12. What is rooting in Android devices, and why is it considered risky?
13. What is jailbreaking in iOS, and how does it differ from Android rooting?
14. Name three common vulnerabilities from OWASP Mobile Top 10.
15. What is APK signing and why is it necessary?

Mobile Penetration Testing Tools & Techniques

16. What is MobSF, and how is it used in mobile penetration testing?
17. How does Burp Suite help in intercepting and modifying mobile traffic?
18. What is Frida, and what types of activities can it perform?
19. What role does TLS interception play in mobile application testing?
20. Explain the difference between static analysis (jadx) and dynamic analysis (sandboxing).

Reverse Engineering and Malware

21. How does JADX help in reverse-engineering Android applications?
22. What is Ghidra, and why is it used in binary analysis?

23. What is an obfuscated mobile application, and how does it hinder attackers?
24. Define RAT (Remote Access Trojan) and give one mobile example.
25. What are common countermeasures against mobile RATs?

Cloud Computing & Docker Security

26. Define cloud computing and list its three main characteristics.
27. Compare the cloud service models: IaaS, PaaS, and SaaS.
28. Explain public, private, and hybrid cloud deployment models.
29. What is Docker, and how does containerization improve application deployment?
30. Explain the role of the Docker Engine in container security.
31. What are Docker images, and how are they stored and distributed?
32. How does a Docker registry differ from Docker Hub?
33. What is a REST API in Docker, and how is it used for automation?

S3 Security & Enumeration Tools

34. What are common misconfigurations in Amazon S3 buckets?
35. What is s3scanner, and how is it used in cloud penetration testing?
36. What is s3Inspector, and how does it help assess bucket security?

Governance, Risk & Compliance (GRC)

37. What is Governance, Risk Management, and Compliance in cybersecurity?
38. Why is GRC essential in information security programs?
39. Name three common audit frameworks used in organizations.
40. What is ISO 27001, and what does it focus on?
41. What is NIST SP 800-53, and how is it applied in risk management?
42. What is COBIT, and how does it differ from ISO 27001?
43. What are the roles and responsibilities of auditors in the security process?
44. Explain the importance of implementing GRC policies in an enterprise.
45. What is the difference between qualitative and quantitative risk analysis?
46. What are common risk mitigation strategies used in cybersecurity?

Scenario-Based Questions (10)

47. A developer uses string concatenation to build SQL queries. What risk exists, and how should it be fixed?
48. A financial Android app crashes when TLS interception is attempted during testing. What security feature may be responsible?
49. During security testing, you discover a public S3 bucket storing sensitive documents. What is the appropriate remediation?
50. While reviewing an APK in JADX, you find hardcoded API keys. What security implications does this create, and what is the best remediation?
51. Your organization must comply with ISO 27001, but no formal risk assessments exist. What steps should be taken first?
52. A mobile app accepts unrestricted file uploads. What threat exists, and how can it be prevented?
53. You find a rooted device running a corporate app. What are the risks, and what policy should be enforced?
54. While testing a Dockerized web application, you discover credentials stored inside a container image. What should be done?
55. A company using public cloud storage wants to ensure least privilege access. Which security controls should be applied?
56. A governance audit reveals missing logs for user access. How should the organization resolve the compliance issue?